

RLS Test Report (real PostgreSQL 16, local)

26/26 assertions. Proven: anonymous cannot read organizations/profiles/memberships/entitlements/invitations/internal-roles/events; customer A sees only its own org + entitlement and cannot read Corp B; customer cannot update pilot dates, activate a pilot, insert an internal role, or change its own membership role; customer B cannot read or update Corp A; internal_notes column is not selectable by customers; ops admin reads across orgs + invitations + internal roles; AAL1 denied and AAL2 authorized via authorize_pilot_session.

No customer-accessible using(true)/with check(true) policy exists. All mutations are reserved to service-role Edge Functions.

NOT VALIDATED IN STAGING: the same policies applied to the live Supabase Postgres. The local database replicates auth.uid()/auth.jwt()/roles faithfully, but staging execution is pending.